

Dalam CTF Jeopardy, serangan terhadap **Mersenne Twister (MT19937)** biasanya muncul karena banyak programmer menganggapnya aman untuk kriptografi, padahal sebenarnya MT19937 hanya PRNG biasa dan bukan CSPRNG.

Apa itu Mersenne Twister?

MT19937 menghasilkan bilangan pseudo-random dengan:

- State internal = 624 buah integer 32-bit
- Total state = $624 \times 32 = 19968$ bit
- Period = $(2^{\{19937\}} - 1)$

Contoh Python:

```
import random
```

```
random.seed(1234)
```

```
print(random.getrandbits(32))
```

```
print(random.getrandbits(32))
```

Jika seed sama, output selalu sama.

Kelemahan MT19937

Ada 3 jenis attack yang sering muncul di CTF.

1. Seed Recovery

Jika seed berasal dari timestamp.

Contoh challenge:

```
import random,time
```

```
seed = int(time.time())
```

```
random.seed(seed)
```

```
print(random.getrandbits(32))
```

Output:

```
218374921
```

Cara menyerang

Bruteforce timestamp.

```
import random,time
```

```
target = 218374921
```

```
now = int(time.time())
```

```
for seed in range(now-10000, now+1):
```

```
    random.seed(seed)
```

```
    if random.getrandbits(32) == target:
```

```
        print("Seed =", seed)
```

```
        break
```

Soal CTF

```
import random,time
```

```
flag = b"FLAG{MT_SEED_ATTACK}"
```

```
seed = int(time.time())
```

```
random.seed(seed)
```

```
key = random.getrandbits(32)
```

```
enc = bytes(x ^ (key & 0xff) for x in flag)
```

```
print(enc.hex())
```

Diberikan:

```
enc = 747e73727a353f...
```

Tugas:

- Cari seed

- Dapatkan key
 - Recover flag
-

2. State Cloning Attack

Ini yang paling populer.

Jika kita memperoleh **624 output 32-bit**, kita bisa membangun ulang seluruh state MT19937.

Kemudian kita bisa memprediksi semua output berikutnya.

Mengapa bisa?

Output MT:

State

↓

Tempering

↓

Output

Tempering:

$y \wedge= y \gg 11$

$y \wedge= (y \ll 7) \& 0x9D2C5680$

$y \wedge= (y \ll 15) \& 0xEFC60000$

$y \wedge= y \gg 18$

Operasi ini bisa dibalik.

Untemper

def untemper(y):

...

Dari output:

o1

o2

...

o624

Kita dapat:

```
state[0]
state[1]
...
state[623]
```

Clone State

```
from randcrack import RandCrack
```

```
rc = RandCrack()
```

```
for _ in range(624):
    rc.submit(random_output)
```

```
print(rc.predict_getrandbits(32))
```

Soal CTF

```
import random
```

```
flag = b"FLAG{CLONE_MT}"
```

```
random.seed(1337)
```

```
for _ in range(624):
    print(random.getrandbits(32))
```

```
key = random.getrandbits(32)
```

```
enc = bytes(x ^ (key & 0xff) for x in flag)
```

```
print(enc.hex())
```

Diberikan:

- 624 output pertama
- ciphertext

Tugas:

- Clone MT
- Prediksi key berikutnya
- Dapatkan flag

3. Recover Seed dari Sedikit Output

Kadang challenge memberi:

```
random.seed(seed)
```

```
x1 = random.getrandbits(32)
```

```
x2 = random.getrandbits(32)
```

Jika seed kecil:

$$0 \leq \text{seed} \leq 2^{16}$$

bisa brute force.

```
import random
```

```
for seed in range(2**16):
```

```
    random.seed(seed)
```

```
    if random.getrandbits(32) == x1:
```

```
        if random.getrandbits(32) == x2:
```

```
            print(seed)
```

Challenge MT19937 yang Lebih Sulit

Kadang flag dibuat seperti:

```
random.seed(secret_seed)
```

```
keystream = random.getrandbits(len(flag)*8)
```

`enc = bytes_to_long(flag) ^ keystream`

Jika cukup banyak output MT bocor:

```
print(random.getrandbits(32))
```

sebanyak 624 kali, maka:

1. Clone state
2. Prediksi keystream berikutnya
3. XOR dengan ciphertext
4. Flag didapat

Tools yang Sering Dipakai

RandCrack

[RandCrack GitHub](#)

`pip install randcrack`

Contoh:

```
from randcrack import RandCrack
```

```
rc = RandCrack()
```

```
for i in range(624):
```

```
    rc.submit(outputs[i])
```

```
print(rc.predict_getrandbits(32))
```

Ringkasan untuk CTF

Informasi Bocor	Serangan
Timestamp seed	Seed brute force
Seed kecil	Bruteforce seed
624 output 32-bit	Clone state
State diketahui	Prediksi semua output berikutnya

Informasi Bocor

Serangan

MT dipakai sebagai stream cipher Recover keystream

Urutan yang paling sering keluar di CTF Jeopardy adalah:

1. Seed dari timestamp.
2. Seed kecil (16-bit atau 32-bit).
3. Clone MT19937 menggunakan 624 output dan RandCrack.
4. Menggunakan state yang berhasil di-clone untuk mendekripsi flag.